EUROPEAN SMBs · E-COMMERCE · AGENCIES

THE DATA *Retention* MISTAKE

Why keeping customer data too long could cost your business



BONUS 1 Policy Template

GDPR RETENTION | BACKUPS & ARCHIVES | STAFF RECORDS

DELETION POLICY · 30-DAY PLAN · SCHEDULES

ZIRLANDIA MILKOVIC



THE DATA *Retention* MISTAKE

Why Keeping Customer Data Too Long Could Cost Your Business: retention periods, deletion policies, backups and employee records under the GDPR

ZIRLANDIA MILKOVIC

FOR EUROPEAN SMBs · E-COMMERCE · AGENCIES

The Data Retention Mistake

Why Keeping Customer Data Too Long Could Cost Your Business: retention periods, deletion policies, backups and employee records under the GDPR

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for printing the worksheets, checklists and the policy template for your own business use.

NOT LEGAL ADVICE. This book is an educational guide to the EU General Data Protection Regulation (Regulation (EU) 2016/679). It is not legal advice, does not create a lawyer-client or consultant-client relationship, and does not take your individual circumstances into account. Reading it, following it or using its templates does not make a business GDPR compliant and is not a certification or a guarantee of compliance.

LAWS CHANGE. Data protection law, regulatory guidance, court decisions and national rules develop continuously. The book reflects the author's understanding as of its publication date (2026) and refers to official sources so that you can check what applies now. National laws, supervisory-authority guidance and sector rules differ between countries. Before you rely on anything here for a decision with real consequences, take advice from a qualified lawyer or data protection professional in the relevant country.

Product and company names (for example email, analytics, advertising and AI platforms) are the property of their respective owners and are used only as examples for identification and education. This independent book is not affiliated with, sponsored by or endorsed by any of them, and no product is recommended or certified as compliant.

Every person, business and incident described in the case studies and scenarios is fictional and was created to illustrate ideas. Any resemblance to real people or companies is coincidental.

Premium Edition 2026 · PDF with clickable contents, bookmarks and fillable worksheets

Contents

Note	A Note from the Author	5
01	The Mistake Nobody Notices	6
02	What the GDPR Actually Says	10
03	The Data Lifecycle	15
04	Customers, Shops and Agencies	19
05	Employee Records and Applicants	24
06	Backups, Archives and the Cloud	29
07	Building Your Deletion System	33
08	Requests, Holds and Awkward Cases	37
09	Ten Costly Retention Mistakes	41
10	Your 30-Day Cleanup Plan	44
Bonus	Data Retention Policy Template	50
A–Z	Plain-English Glossary	56
Ref	Official Sources & Further Reading	57
Bio	About the Author	58

A Note from the Author

Why this book is about the one GDPR habit almost every business gets wrong.

Almost every business I speak to has a rule for collecting data. Almost none has a rule for letting it go.

The order spreadsheet from 2017 is still in the shared drive. The newsletter list still holds people who stopped opening your emails years ago. A former employee's folder is sitting in an inbox nobody checks. The agency's old client files live in three tools, two laptops and a backup nobody has ever tested. No one decided to keep any of it. It simply stayed, because deleting felt risky and keeping felt free.

Keeping is not free. Every record you hold is a record that can leak, be requested, be wrongly used or be found by a regulator. The longer you keep it, the more it can cost you, and the less reason you have to say why it is still there.

This short guide is written for European small businesses, online shops and agencies. It explains in plain English what the GDPR says about keeping data, how to set sensible retention periods, how to handle backups and employee records, and how to build a deletion habit your team will actually follow. At the back you will find a ready-to-adapt **Data Retention Policy template** and a retention schedule you can fill in.

> AI & PRIVACY **How to use this book**
>
> Read Chapters 1 to 3 for the principles. Jump to the chapter for your situation (customers and shops in Chapter 4, staff in Chapter 5, backups in Chapter 6). Then use Chapters 7 to 10 and the Bonus template to put a system in place. The retention periods quoted are **examples and starting points, not legal rules**: always confirm the periods that apply in your country.

PART I · WHY KEEPING DATA IS A RISK

CHAPTER

01

The Mistake Nobody Notices

Why "we might need it someday" is the most expensive sentence in data protection.

IN THIS CHAPTER

- What the data retention mistake is, and why it is so common
- The four hidden costs of keeping data too long
- What three real enforcement cases teach small businesses
- Where the habit comes from, and how to spot it in your own business

Picture a small online shop, five years old. It has sold to 38,000 customers. Every one of them left a name, an address, a phone number and an order history. Roughly 6,000 still buy each year. The other 32,000 bought once, years ago, and never came back.

Ask the owner why the old records are still there and the answer is always honest and always the same: "*I might need them one day.*" That sentence feels prudent. Under the GDPR it is a problem, because "someday" is not a purpose, and data without a purpose has no business being kept.

What the mistake actually is

The **data retention mistake** is keeping personal data for longer than you need it, or without ever deciding how long that should be. It is rarely a deliberate choice. It is the default outcome of busy people, cheap storage and tools that never forget. Nobody sets out to hoard. Hoarding happens when nobody is asked to delete.

The rule it breaks is one of the seven core principles of the GDPR, **storage limitation** (Article 5(1)(e)): personal data must be kept in a form that identifies people for no longer than is necessary for the purposes for which it is processed. The same article adds the accountability principle (Article 5(2)): you must be able to show that you comply. Put together, they mean you need two things: a reason to keep each type of data, and an end date, or a clear rule for when it ends.



Retention in four numbers

Notice the second figure. The GDPR does not say keep data for six months, or two years, or seven. It gives you a test (is it still *necessary*?) and expects you to explain your answer. Tax, accounting and employment laws sometimes set minimum periods; Chapter 2 deals with those.

The four hidden costs of keeping too much



Figure 1 What old data really costs you

REAL-WORLD SCENARIO **Real-world scenario: the breach that did not need to be big**

A small design agency is hit by a phishing attack on a shared mailbox. The attacker finds eight years of client onboarding emails: passports scanned for a long-finished identity check, bank details and signed contracts. The agency needed none of these after the work ended. A breach of one year's data became a breach of eight, and the notification list grew from forty people to over three hundred.

What regulators have actually done

Retention is not a theoretical risk. Regulators across Europe have acted on it, including against ordinary commercial businesses. Three well-documented cases show the pattern. Please read them as illustrations of how authorities think, not as templates for what a small business will face.

2019 — **Deutsche Wohnen (Germany)**
The Berlin data protection authority fined the property company €14.5 million, citing an archive system that did not allow data to be deleted when no longer needed. The case later went to the EU Court of Justice on a question about fault (December 2023); check the current status of the proceedings.

2019 — **Taxa 4x35 (Denmark)**
The Danish authority recommended a fine of DKK 1.2 million and referred the taxi company to the police. It had removed customers' names after two years but kept the phone numbers linked to millions of trips, and argued that its system made earlier deletion difficult.

2020 — **Spartoo (France)**
The French CNIL fined the online shoe retailer €250,000, finding among other things that it kept data on millions of customers who had been inactive for more than five years, and that a hashed password and email still counted as personal data.

Figure 2 Three retention cases worth knowing

GDPR IN PLAIN ENGLISH **What these cases have in common**

The authorities did not ask whether there had been a breach. They asked a simpler question: **why do you still have this?** In each case the answer was "our system makes it hard" or "we might need it", and neither was accepted. A technical limitation does not excuse a legal obligation.

Why smart people fall into the trap

"DELETING FEELS RISKY"

If you are unsure whether you might need something, keeping it feels safer. The real risk of keeping is simply less visible.

"STORAGE IS CHEAP"

The cost of storing a gigabyte is close to zero. The cost of defending why you kept it is not.

"THE TOOL REMEMBERS"

CRMs, email platforms and shops store everything by default. Nobody switches on automatic deletion.

"NOBODY OWNS IT"

Retention belongs to everyone, which means it belongs to no one. Without an owner, nothing is ever deleted.

Figure 3 Four habits behind the mistake

THE 10-MINUTE RETENTION REALITY CHECK

- [ ] I can name the oldest customer record in my main system.
- [ ] I know whether I still need it, and I can say why.
- [ ] My newsletter list contains people who have not opened anything for over two years.
- [ ] I know how long each main category of data is kept.
- [ ] My privacy notice states those periods or the criteria for them.
- [ ] Someone is named as the owner of retention and deletion.
- [ ] I know what happens to the data of a customer who leaves.
- [ ] I know whether our backups are covered by any deletion rule.
- [ ] We have deleted something on purpose in the last twelve months.

DO THIS NOW **Do this now (10 minutes)**

Open your main customer system, sort by oldest record, and read the first ten entries. For each, write one sentence: why do I still have this? If you cannot write the sentence, you have found your first retention problem.

PART I · WHY KEEPING DATA IS A RISK

CHAPTER

02

What the GDPR Actually Says

The handful of Articles that govern how long you may keep personal data, in plain English.

IN THIS CHAPTER

— The six GDPR provisions that matter for retention
— Why the law gives you no magic number of years
— How "legal minimums" from other laws fit in
— What you must tell people about how long you keep their data

Retention rules are scattered across the GDPR rather than collected in one place. That is why so many businesses miss them. Here is the whole picture on one page, then we take each piece in turn.



Figure 4 Where retention appears in the GDPR

The core rule: Article 5(1)(e)

Personal data must be "kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed." Two ideas are packed into that sentence. First, **retention is tied to purpose**: when the purpose ends, the reason to keep the data in identifiable form ends with it. Second, the test is **necessity**, not convenience or possibility.

There is a narrow exception: data may be kept longer when it is processed only for archiving in the public interest, scientific or historical research or statistical purposes, with appropriate safeguards (Articles 5(1)(e) and 89). That is not a route for a shop or agency to keep customer files indefinitely.

> WHAT GDPR REQUIRES **What GDPR requires**
>
> You must be able to say, for each category of personal data you hold, **what it is for and when that purpose ends**. Recital 39 spells out the practical consequence: the controller should set time limits for erasure or for a periodic review.

The accountability twist

Article 5(2) says you are responsible for compliance *and* must be able to demonstrate it. For retention, that means writing your decisions down. A schedule that says "customer orders: seven years because of tax law" is evidence of a decision. A shrug and "we have always kept them" is not.

Telling people how long you keep their data

When you collect personal data, you must tell people **the period for which it will be stored, or, if that is not possible, the criteria used to determine that period** (Article 13(2)(a), and Article 14(2)(a) when you got the data from someone else). The same information must be given to anyone who makes an access request (Article 15(1)(d)).

BEFORE & AFTER **Retention statements in a privacy notice**

RISKY	*We keep your data for as long as necessary for business purposes.*
BETTER	*We keep order records for 7 years as required by tax law, and newsletter details until you unsubscribe.*
BEST PRACTICE	*Orders and invoices: 7 years (tax law). Newsletter: until you unsubscribe, then your email stays on a suppression list so we do not message you again. Support emails: 2 years after the case closes. Website security logs: 90 days.*
WHY IT MATTERS	Specific periods show you have decided. Vague wording signals that you have not, and regulators read it that way.

The right to erasure

People can ask you to delete their data in several situations, including when it is **no longer necessary** for the purpose you collected it for, when they withdraw consent and you have no other basis, and when they object to processing that you cannot justify (Article 17(1)). You must act without undue delay, normally within one month of the request (Article 12(3)).

The right is not absolute. You may keep data you need to comply with a legal obligation or to establish, exercise or defend legal claims (Article 17(3)). Chapter 8 explains how to handle these cases.

Records of processing

Article 30 requires many organisations to keep a **record of processing activities**, which for each activity includes, where possible, the expected time limits for erasing the different categories of data (Article 30(1)(f)). Smaller organisations (fewer than 250 people) benefit from a limited exemption, but it does not apply where processing is not occasional, which covers most customer and staff data. In practice, almost every business with regular customers or employees should keep one. Your retention schedule can double as this part of the record.

When another law says you must keep it

Many national laws require certain records to be kept for **minimum periods**: tax and accounting records, payroll and social security records, anti-money-laundering checks in regulated sectors, and product-safety or warranty obligations. When a law requires you to keep data, that is your lawful basis for keeping it (Article 6(1)(c)), and you can refuse an erasure request for that data for as long as the law demands.

> WATCH OUT **Two traps with legal minimums**
>
> **A legal minimum is a floor for the specific records the law names, not a licence to keep everything.** The tax office needs your invoices, not the customer's browsing history. And when the legal period ends, the legal reason to keep that data ends with it, unless another purpose applies.



Figure 5 How to decide how long to keep a record

FOUNDER TIP **Founder Tip: write the "because"**

Next to every retention period in your schedule, add one line starting with "because". "Seven years, because Article 6(1)(c) applies through national tax law." "Two years, because warranty claims can arrive up to two years after delivery." If you cannot finish the sentence, the period is a guess.

CHECK YOUR UNDERSTANDING

Which Article tells you that retention must be tied to purpose?

What must your privacy notice say about retention?

When can you refuse a deletion request, and for how long?

What is the difference between a legal minimum and a business need?



PART I · WHY KEEPING DATA IS A RISK

CHAPTER

03

The Data Lifecycle

From the moment data arrives to the day it leaves: where the clock starts and what happens when it stops.

IN THIS CHAPTER

- The five stages every piece of data passes through
- How to choose the trigger that starts the retention clock
- The three things you can do when a period ends
- A simple way to map your own data in an afternoon

Most businesses think carefully about the first half of a record's life: how to collect it, where to store it, who can use it. The second half is where the mistake happens. A good retention system treats the end of life as a planned stage, not an afterthought.



Figure 6 The life of a piece of personal data

When does the clock start?

A retention period is meaningless without a **trigger**, the event that starts the clock. Choosing the wrong trigger is the most common technical error in retention schedules. "Keep for two years" is incomplete: two years from *what*?

Common triggers

Trigger	Used for	Example
Date of collection	Short-lived data with no ongoing relationship	Website enquiry form: 12 months from submission
End of the relationship	Customers, clients, members	Service customer: 3 years after the contract ends
End of the financial year	Accounting and tax records	Invoices: 7 years from the end of the year they relate to
Last meaningful activity	Accounts and marketing lists	Inactive account: 24 months after last purchase or login
Event or decision	Recruitment, disputes, projects	Rejected applicant: 6 months after the decision
Fixed length	Technical logs, CCTV, security data	Server logs: 90 days from creation

WATCH OUT **The "last activity" trap**

Be careful what you count as activity. French regulator guidance and enforcement have rejected the idea that simply *opening a marketing email* proves someone is still a customer, because it can happen by accident. A real purchase, a login, a reply or a deliberate update of preferences is a safer signal.

What happens when the period ends

At the end of a period you have three options. Pick one deliberately, and record which.

DELETE
Erase the data permanently from live systems, and from backups according to your backup rule (Chapter 6). This is the default for most records.

ANONYMISE
Irreversibly remove identifiers so that nobody can link the data to a person, then keep the statistics. Truly anonymous data falls outside the GDPR (Recital 26), but it is a high bar.

KEEP WITH A NEW REASON
Document a different, specific, current purpose, such as a legal claim in progress, and set a new review date. "Just in case" is not a reason.

Figure 7 The three end-of-life options

> **GDPR IN PLAIN ENGLISH** **Pseudonymised is not anonymous**
>
> Replacing names with codes, or hashing an email address, is **pseudonymisation** (Article 4(5)). It is a good security measure, but the data is still personal data if anyone can link it back. In the Spartoo case the French authority held that hashed emails and passwords still had to be erased when the retention period ended.

Map your data in an afternoon

You do not need special software. You need a spreadsheet and an honest walk through your business. Work through these questions for each system you use: your shop platform, email tool, CRM, accounting software, shared drive, helpdesk, HR files, phones and any paper.

1. List every place personal data is stored. Include inboxes, exports, and downloads folders, because that is where forgotten copies live.
2. For each place, list the categories of data: customer, prospect, employee, supplier, website visitor.
3. For each category, write the purpose it serves today.
4. Find the oldest record and ask whether the purpose still applies to it.
5. Choose the trigger, the period and the action, and write the "because".
6. Name an owner for each line.

1	**Is the original purpose (order, service, support, employment) still active?**	**YES** Keep it, and review at the next scheduled date	**NO** Continue to question 2
2	**Does a law require me to keep it (tax, accounting, payroll, sector rules)?**	**YES** Keep only the required records, for the required period, then move to question 5	**NO** Continue to question 3
3	**Is there a live dispute, claim or investigation that this record relates to?**	**YES** Apply a legal hold, restrict use and review when it ends (Chapter 8)	**NO** Continue to question 4
4	**Has the person agreed to me keeping it for a further, specific purpose (for example a mailing list)?**	**YES** Keep it for that purpose only and record the consent	**NO** Continue to question 5
5	**Can I achieve my goal with anonymised or aggregated data instead?**	**YES** Anonymise it and keep the statistics	**NO** Delete it and note the date in your deletion log

Figure 8 Do I still need this record?

DO THIS NOW **Do this now (30 minutes)**

Pick **one** system, your CRM or shop is a good start, and complete the six steps above for it alone. A finished map of one system teaches you more than a half-finished map of ten.

PART II · RETENTION IN PRACTICE

CHAPTER

04

Customers, Shops and Agencies

Practical retention starting points for the data an SMB, an e-commerce store or an agency really holds.

IN THIS CHAPTER

- A retention schedule for typical customer and shop data
- How to treat marketing lists, abandoned carts and inactive accounts
- What agencies must do with client data they handle for others
- Why the right period is the shortest one you can justify

WATCH OUT **Read this before the table**

The periods in this chapter are **illustrative starting points**, based on common practice and regulator guidance, not legal rules. Tax, accounting, consumer and sector laws differ from country to country. Confirm the minimum periods that apply to you with your accountant or national authority, then write down your own.

A starting schedule for customer data

Illustrative retention starting points

Data	Typical period	Trigger	Why (check locally)
Invoices and order records	Often 5 to 10 years	End of the financial year	Tax and accounting law (Art. 6(1)(c))
Customer contact details for an active customer	Duration of the relationship	Last purchase or contract end	Contract performance
Customer details after the relationship ends	Often 1 to 3 years	Last order	Warranty, complaints, returns, limitation period
Support emails and tickets	1 to 2 years	Case closed	Handling complaints and repeat issues
Marketing consent records	As long as you market, then a short period	Withdrawal or last contact	Proof of consent (Art. 7(1))
Inactive newsletter subscribers	Commonly 2 to 3 years	Last real interaction	Marketing purpose has lapsed
Website enquiry from a non-customer	6 to 12 months	Date of enquiry	Answering the enquiry
Abandoned cart data	Days to a few weeks	Cart creation	Recovering the sale only
Analytics and security logs	30 to 90 days for logs; analytics per your tool settings	Creation date	Troubleshooting, security

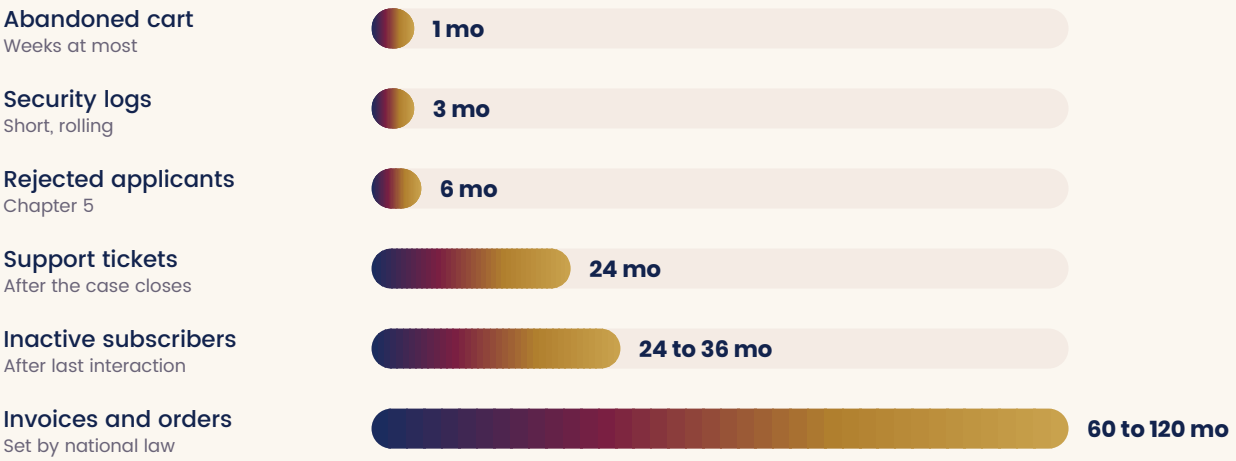


Figure 9 Illustrative horizons in months (log scale, good-practice starting points)

Marketing lists: the biggest hidden stockpile

Marketing data accumulates faster than any other category, and it ages worst. A contact who last engaged four years ago is not an asset. They are a compliance liability and a deliverability problem, because dormant addresses drag down your sender reputation.

GOOD PRACTICE **Good practice: the sunset policy**

Define "inactive" (for example: no purchase, no click, no reply in 24 months). Send one re-engagement email asking if they want to stay. Remove those who do not respond. **Keep a minimal suppression record** (just the email address and the fact that they opted out) so you never email them again. This is lawful, because honouring an objection to marketing requires you to remember it (Article 21(2) and (3)).

E-commerce: keep orders, not everything around them

An online shop collects far more than the order: browsing behaviour, saved baskets, wishlists, device data, delivery notes, chat transcripts and returns forms. Your tax duty applies to the **financial record**, not to all of it.

RISKY: KEEP EVERYTHING FOREVER

- Customer accounts never expire, even after five years of inactivity.
- Payment card details and ID scans are kept "for convenience".
- Chat logs and wishlists are kept with no limit.
- Old marketing exports sit in downloads folders.

BETTER: KEEP WHAT IS NEEDED, FOR AS LONG AS NEEDED

- Inactive accounts are flagged after 24 months and closed after a warning.
- Card details stay with the payment provider, and ID scans are deleted once checked.
- Chat logs and returns notes are deleted after 12 to 24 months.
- Exports are deleted once their one use is finished.

Figure 10 Two e-commerce retention approaches

Agencies: you are often a processor, not the owner

If you run an agency, freelance studio or consultancy, much of the data you hold belongs to your **clients**: their customer lists, their email platforms, their analytics. In GDPR terms you are usually a **processor** acting on their instructions, and your client is the controller.

That changes retention. You do not decide how long that data is kept; the client does, through your contract. Article 28(3)(g) requires the contract to say that, at the controller's choice, you delete or return all personal data when the services end, and delete existing copies unless the law requires storage. Many agencies fail here because project files, exports and test databases linger on laptops long after the contract ends.



Figure 11 The end-of-project routine for agencies

FOUNDER TIP **Founder Tip: put it in the contract**

Add two lines to every client agreement: what happens to data when the project ends, and how many days you have to complete deletion (for example 30). Then add "delete client data" to your project-closing checklist so it happens without anyone having to remember.

Your own agency data

Agencies also hold their own business data: proposals, enquiries, billing records and staff files. Treat these like any small business: apply the same schedule logic, and do not mix them with client data in the same folders. Mixed folders are where accidental retention hides.

CUSTOMER-DATA RETENTION CHECK

- [ ] Every customer-data category has a stated period and a trigger.
- [ ] Marketing lists are cleaned at least once a year.
- [ ] Inactive accounts are closed after a warning.
- [ ] Card details are stored by the payment provider and never by us.
- [ ] Identity documents are deleted once the check is complete.
- [ ] Client data is deleted at project end, with written confirmation.
- [ ] Test databases and exports are deleted when they are no longer used.

PART II · RETENTION IN PRACTICE

CHAPTER

05

Employee Records and Applicants

The people data you hold about your own team, from the first CV to years after they leave.

IN THIS CHAPTER

- Why employee data is the most sensitive retention area for most SMBs
- Typical periods for applicants, payroll, contracts, absence and CCTV
- What to do on the day someone leaves
- How to handle manager notes, emails and shared accounts

Employee data is different from customer data in three ways. It is **more sensitive** (health, family, pay, performance), it is held in **a relationship with an imbalance of power**, and it is governed by **layers of national employment law** on top of the GDPR. The GDPR even allows Member States to add more specific rules for employment (Article 88). That makes this the area where checking local rules matters most.

> **WATCH OUT** **Check local law first**
>
> Retention periods for payroll, working-time, tax, social security, health and safety, and limitation periods for employment claims vary widely between countries. Use the table below to understand **what categories to think about**, then confirm the periods with your accountant, payroll provider or national authority.

The employee lifecycle

Stage 1 — **Recruitment**
CVs, cover letters, interview notes. Short retention unless the candidate agrees to a talent pool.

Stage 2 — **Employment**
Contract, payroll, bank details, absence, appraisals. Kept for the duration of employment as necessary for each purpose.

Stage 3 — **Leaving**
Exit paperwork, final pay, access removal. The clock for most records starts now.

Stage 4 — **After leaving**
Only records the law or a live claim requires. Everything else is deleted on a schedule.

Figure 12 From application to long after leaving

A practical schedule

Illustrative employee-data starting points

Record	Typical period	Trigger	Notes
Unsuccessful applications	Commonly 6 to 12 months	Decision date	Local limits for discrimination claims may set the length; ask candidates before keeping longer
Talent-pool CVs	Until consent is withdrawn; review yearly	Consent date	Needs real, separate consent
Employment contract and core HR file	Often several years after leaving	Termination	Depends on limitation periods and national law
Payroll and tax records	Often 5 to 10 years	End of tax year	Required by tax and social-security law
Sickness and health records	As short as possible	Return to work	Special category data (Art. 9); keep only what is necessary
Disciplinary records	Per policy, often 6 to 24 months for warnings	Date of warning	Delete when the warning expires
Right-to-work or ID copies	Per national law, then delete	Employment end	Do not keep more than the law needs
CCTV footage	Often around 30 days	Recording date	Longer only if an incident needs it
Work email of a leaver	Close promptly; archive only what is needed	Last day	Do not keep full mailboxes by default

WHAT GDPR REQUIRES **What GDPR requires**

Employees have the same rights as customers: they must be told how long their data is kept (Articles 13 and 14), can ask for a copy of it (Article 15), and can ask for deletion where the data is no longer necessary (Article 17). A staff privacy notice that states retention periods is a legal requirement, not a courtesy.

Recruitment: the quiet stockpile

Hiring creates a flood of personal data in a short time: CVs by email, application forms, interview notes, reference checks. Rejected candidates are not your employees and never became your customers, so you need a clear reason to keep their data. A claim of discrimination is the usual one, and it sets a short window.

BEFORE & AFTER **Handling a rejected candidate**

RISKY	*Keep every CV in a shared folder "in case a role comes up".*
BETTER	*Delete applications 6 months after the decision, unless the candidate has agreed to stay on file.*
BEST PRACTICE	*State the period in the job advert. Ask for optional, separate consent for a talent pool with a 12-month limit. Review the pool every year and send a short "still interested?" note before removal.*
WHY IT MATTERS	Candidates who are told the rules trust the process. A shared folder of old CVs is also one of the first things a breach exposes.

The leaver routine



Figure 13 What to do when someone leaves

FOUNDER TIP **Founder Tip: the mailbox decision**

A former employee's mailbox often holds client correspondence, personal messages and HR matters. Set a rule: auto-reply for a short period, forward live client messages to a colleague, then close the mailbox. Keep nothing "just in case".

REAL-WORLD SCENARIO **Real-world scenario: the forgotten folder**

Marta joined a design studio in 2019 and left in 2022. Her shared folder still contains a scan of her passport, her bank details and a sick note. In 2026 she submits an access request and the studio realises it kept all of it, with no reason beyond the fact that nobody deleted it. The access request takes days of searching, and the passport scan raises an obvious question: why was it still here four years later?

Monitoring and CCTV

Cameras, access-control logs, keystroke monitoring and location trackers generate data constantly. Employers need a clear purpose and proportionality, and short retention is the easiest way to stay proportionate. For CCTV, many authorities point to retention measured in days or weeks (commonly around 30 days) unless a specific incident requires footage to be kept as evidence.

EMPLOYEE-DATA RETENTION CHECK

- [ ] Staff have a privacy notice that lists retention periods.
- [ ] Rejected applicants' data is deleted on a schedule.
- [ ] Health and absence notes are kept separately and for the shortest period.
- [ ] Payroll records are kept only as long as tax law requires.
- [ ] There is a written leaver routine that includes data deletion.
- [ ] CCTV and access logs overwrite automatically after a short fixed period.

PART II · RETENTION IN PRACTICE

CHAPTER

06

Backups, Archives and the Cloud

The places data hides after you think you deleted it.

IN THIS CHAPTER

- Why deleting from your live system is only half the job
- A defensible rule for backups, with a worked example
- How to find shadow data in email, exports, chats and SaaS tools
- What to ask cloud providers about deletion

You delete a customer from your CRM. Their record vanishes from the screen. But a copy exists in last night's backup, in the monthly export your assistant downloaded, in the email thread where you sent their details to the accountant, and in the project management tool where someone pasted their address. **Deletion is a journey across systems, not a button.**

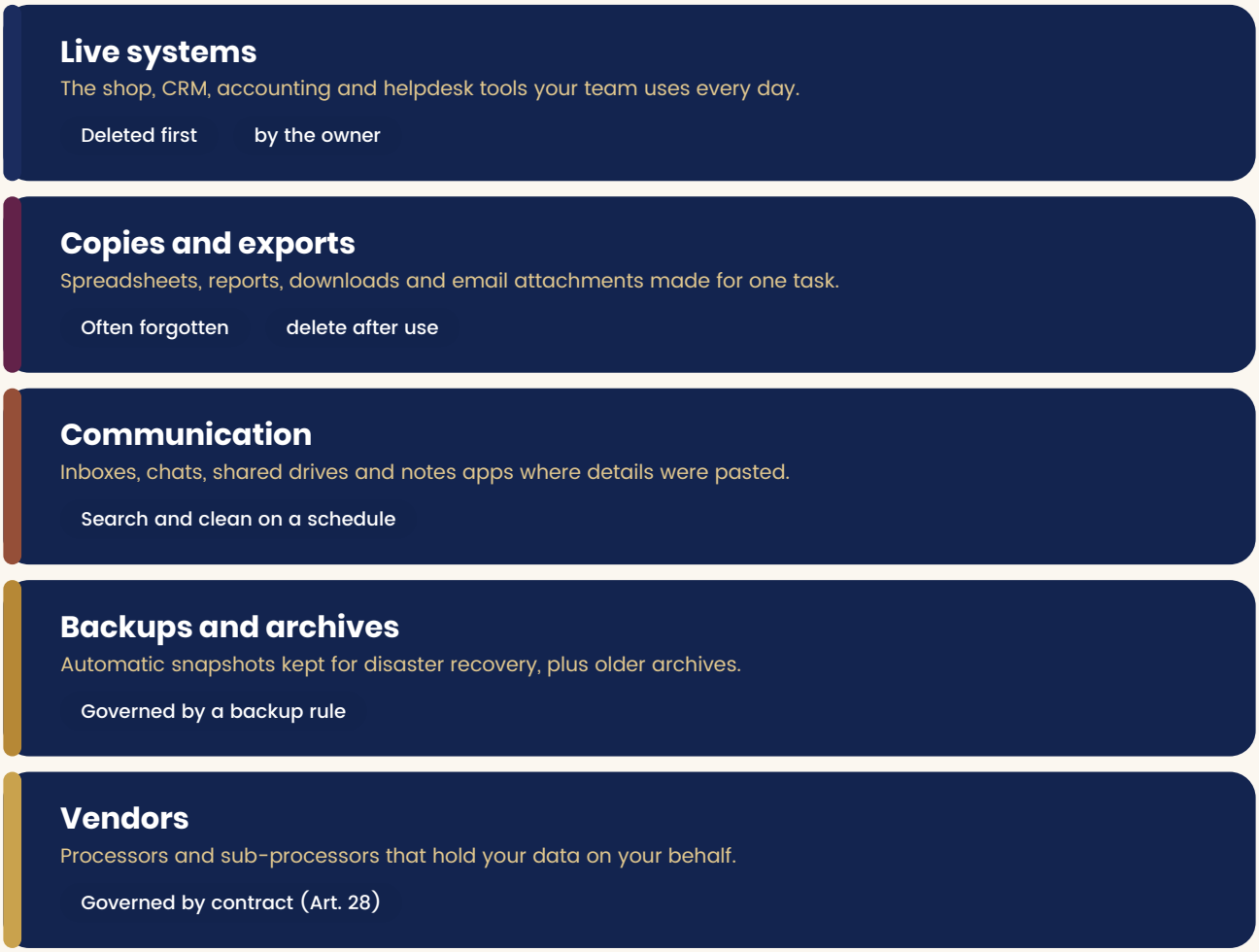


Figure 14 Where a single record usually lives

The backup problem

Backups exist to restore your business after a failure. They are not designed for picking out one person's record. Most regulators accept this reality, but with conditions: backups must be kept for a **limited, defined period**, protected, and not used for any other purpose. They are not a back door for keeping data you were supposed to delete.

WHAT GDPR REQUIRES **What GDPR requires**

Security and availability duties (Article 32) justify keeping backups. Storage limitation (Article 5(1)(e)) means backups must not be kept forever. The two meet in a **documented backup rotation**: how often you back up, how long each copy is kept, and what happens to data that was deleted from live systems after a restore.

A defensible backup rule

1. Set a rotation, for example daily backups kept for 30 days, then monthly backups kept for 6 to 12 months.
2. Make sure old backups are overwritten or destroyed automatically at the end of the rotation.
3. Write down the rule and the reason for each period in your retention schedule.
4. Define a **re-deletion procedure**: after any restore, re-apply the deletion log so people whose data was erased do not return.
5. Never use backups for analysis, testing, marketing or anything but recovery.
6. Test a restore at least once a year, and confirm the re-deletion step works.

REAL-WORLD SCENARIO **Real-world scenario: the zombie customer**

A shop owner deletes a customer after an erasure request. Three months later a server fault forces a restore from backup, and the customer's record reappears. The next marketing campaign emails them. They complain, and the shop cannot show a re-deletion step. The fix is simple: keep a **deletion log** of erasure requests, and re-run it after every restore.

Shadow data: the copies you never meant to keep



Figure 15 Five places to look first

Cloud tools and processors

Every cloud service you use, from your email platform to your CRM, stores data on your behalf. Each is a processor, and each should have a **data processing agreement** (Article 28). When you review a vendor, check retention in three places.

Questions to ask every vendor

Question	What a good answer looks like
Can I set my own retention period or auto-delete rule?	Yes, per data type, with a clear setting you can find
What happens when I delete a record?	Removed from live systems immediately, and from backups on a stated schedule
What happens when I cancel the contract?	Data is deleted or returned within a stated number of days, with confirmation
Do you use sub-processors, and do they delete too?	Yes, listed, with the same obligations

WATCH OUT **AI tools and chat logs**

Prompts, uploads and chat history in AI tools are data too. Check the account's data controls: whether history is stored, for how long, whether it trains models, and whether it can be deleted.

DO THIS NOW **Do this now (20 minutes)**

Find the backup rule for your most important system. Write it in one line: "Daily backups kept X days, monthly kept Y months, automatically deleted after." If you cannot find it, ask your provider today. That one answer fills a gap most small businesses never notice.

PART III · BUILDING THE SYSTEM

CHAPTER

07

Building Your Deletion System

Roles, schedules, automation and evidence: turning good intentions into something that happens every month.

IN THIS CHAPTER

- The four parts of a retention system that works
- Who should own retention in a small business
- How to automate deletion and where to do it by hand
- What evidence to keep, and what not to keep as evidence

A policy that lives in a drawer does not delete anything. The difference between a retention document and a retention **system** is that the system has people, rhythm and proof.

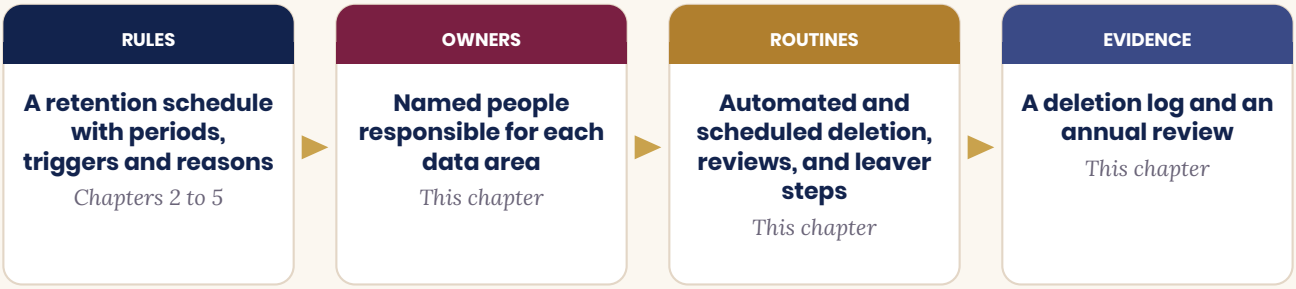


Figure 16 The four parts of a working retention system

Give retention an owner

In a team of three, the owner is probably you, and that is fine. In a team of thirty, split ownership by area. The role does not need a legal degree. It needs the authority to say "this goes" and the discipline to check it did.

A simple ownership model

Area	Typical owner	Responsible for
Customers and marketing	Head of marketing or founder	Lists, CRM, newsletter clean-up
Orders and finance	Finance lead or accountant	Invoice retention, legal minimums
Staff and applicants	HR lead or office manager	Recruitment files, leavers, payroll records
IT and systems	IT lead or provider	Backups, logs, automated deletion, access removal
Projects and clients (agencies)	Project lead	End-of-project deletion and confirmation

Automate first, schedule the rest

AUTOMATE

Use the tool's own settings: auto-delete for logs, rolling backups, cart expiry, mailbox retention, helpdesk archive rules. Automation is consistent and does not depend on anyone remembering.

SCHEDULE

Put a recurring task in the calendar for what tools cannot do: quarterly list clean-ups, annual HR file reviews, end-of-project deletion, yearly backup restore test.

Figure 17 Two ways to delete



Figure 18 Four levels of retention maturity

What to delete, and how

"Delete" must mean something real. Moving a record to a "trash" folder, hiding it in a view or marking it inactive is not deletion. Define what you will do for each kind of storage.

What deletion means in practice

Storage	Acceptable deletion	Not enough
Cloud tool	Permanent removal, including trash and recycle bin	Archiving or "inactive" flag
Spreadsheet or file	Permanent delete from every folder, and from sync copies	Moving to another folder
Email	Delete and empty deleted items; check shared mailboxes	Leaving in an archive
Laptop or drive	Secure erase or wipe when the device is retired	Dragging to the bin
Paper	Cross-cut shredding or certified destruction	Ordinary bin

Keep evidence, not the data

Accountability (Article 5(2)) means being able to show you deleted. Keep a **deletion log** that records *what* category was deleted, *when*, *who* did it and *under which rule*. The log should not contain the personal data itself.

DELETION LOG

Date	Data category	System or location	Rule applied	Done by	Notes
e.g. 2026-03-01	*Inactive newsletter subscribers*	*Email platform*	*Marketing sunset, 24 months*	*A. Smith*	*1,240 contacts removed; suppression list kept*

GOOD PRACTICE **Good practice: the annual review**

Once a year, review your schedule. Ask: are the periods still right? Has the law or guidance changed? Have we started using new tools or collecting new data? Update the schedule and record the date of the review. Recital 39 explicitly encourages periodic review.

PART III · BUILDING THE SYSTEM

CHAPTER

08

Requests, Holds and Awkward Cases

When a customer asks you to delete, when you must not, and what to do when the rules collide.

IN THIS CHAPTER

- How to handle an erasure request step by step
- When you can refuse, and how to say so properly
- How a legal hold works and when it ends
- Disputes, chargebacks, minors and other tricky situations

The theory is easy: delete when you no longer need it. The hard part is the real-life moment when a customer writes "please delete everything you have about me" on the same day your accountant says you must keep their invoice. This chapter gives you a calm way through.

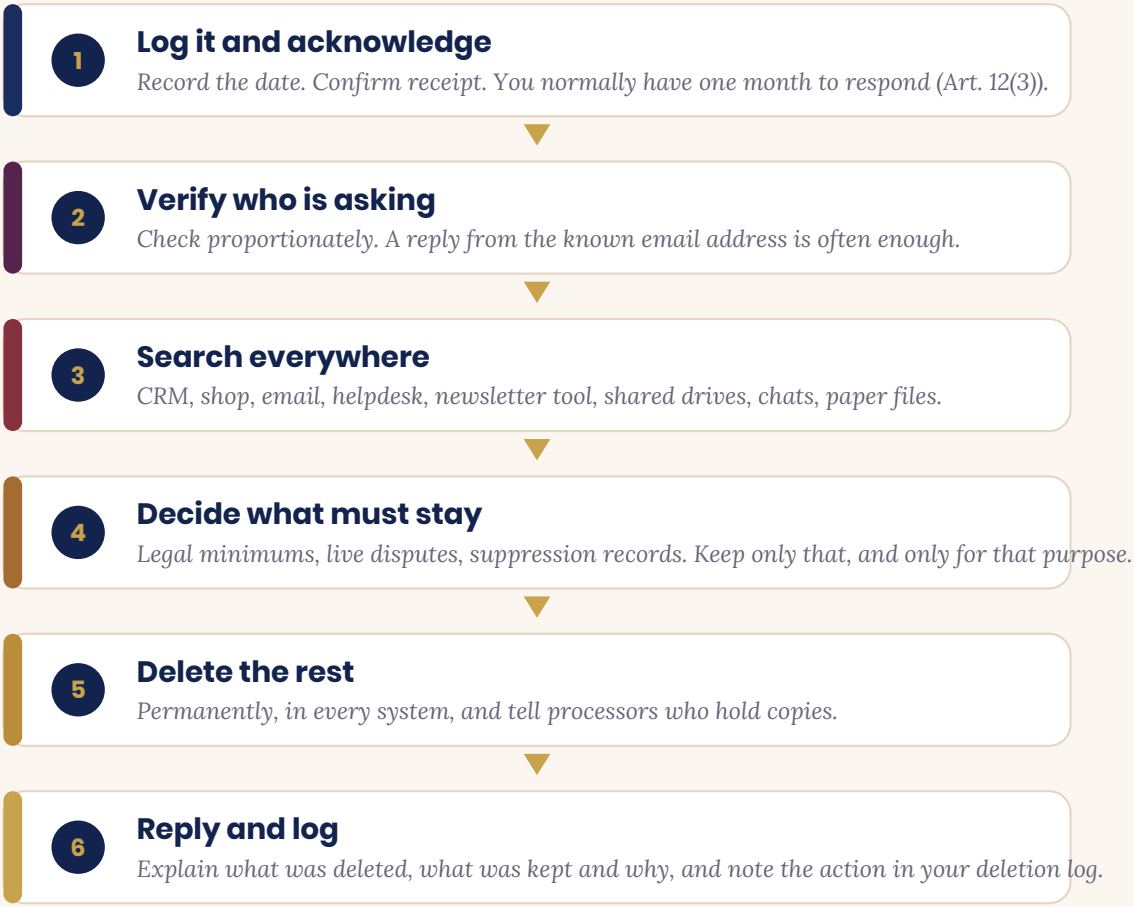


Figure 19 Handling an erasure request, step by step

What you may keep after an erasure request

Article 17(3) lists the main situations where the right to erasure does not apply. For most small businesses the relevant ones are **compliance with a legal obligation** (such as keeping invoices) and **the establishment, exercise or defence of legal claims**. You may keep the data covered by the exception, not the whole customer file.

BEFORE & AFTER **Replying to an erasure request**

RISKY	*Sorry, we cannot delete your data because of GDPR.*
BETTER	*We have deleted your account and marketing data. We must keep your invoices for 7 years under tax law.*
BEST PRACTICE	*We have deleted your account, order notes, support emails and marketing data. We keep only your invoices and payment records for 7 years because tax law requires it, and a suppression record so we do not email you again. We will delete the invoices at the end of that period. You may complain to your data protection authority if you disagree.*
WHY IT MATTERS	A good reply names what was deleted, what was kept, the reason and the end date. It treats the person with respect and shows you actually thought about it.

Legal holds

Sometimes you must **preserve** data that you would normally delete: a customer is threatening a claim, a regulator opens an investigation, a former employee starts a dispute. A **legal hold** pauses deletion for the specific records that relate to the matter.

START
Name the matter, the records concerned and the person who decides. Suspend automatic deletion for those records only.

RESTRICT
Limit access to those who need it. Do not use the data for anything else. Article 18 allows restricting data you need for legal claims.

END
When the matter closes and the limitation period has passed, release the hold, record the date and delete as normal.

Figure 20 How a legal hold works

WATCH OUT **A hold is not a licence to keep everything**

A hold applies to records relevant to a specific matter. "We might be sued someday" does not justify a hold on the whole customer database. Get legal advice if a real claim is possible.

Common awkward cases

Tricky situations and a sensible approach

Situation	Approach
Customer disputes a charge and requests deletion	Keep the transaction and dispute records until the dispute and chargeback window close, then delete
Customer asks to be removed from marketing	Stop marketing at once. Keep a suppression record so they are not re-added
Customer asks you to delete data you gave to your accountant	Tell the accountant. Legal retention may apply to the accountant's copy
Data of a child or teenager	Be especially careful. Apply short periods and make deletion easy
Employee asks for deletion during employment	Assess record by record: payroll must stay, optional records may go
A supplier's contact details	Keep while the relationship lasts, then delete or review after a short period
Data in AI tools or chatbot logs	Check the tool's settings and delete the conversation history that contains personal data

REAL-WORLD SCENARIO **Real-world scenario: two good reasons, one record**

An agency receives an erasure request from a former client contact. The agency still has the signed contract, which it needs for a possible warranty dispute. It deletes the contact's marketing profile, emails and notes, but keeps the contract until the claim period ends. The reply explains this clearly. The contact accepts. **Partial deletion, clearly explained, is a legitimate answer.**

ERASURE-REQUEST READINESS

- [ ] I know who receives requests and where they are logged.
- [ ] I can search all my systems within a week.
- [ ] I know which records I must keep, for how long and why.
- [ ] I have a template reply that explains what was kept and why.
- [ ] My processors know how to delete on my instruction.
- [ ] I log every deletion without storing the deleted data.

PART IV · PUTTING IT TO WORK

CHAPTER

09

Ten Costly Retention Mistakes

The patterns that turn up again and again, each with a quick fix you can apply this week.

IN THIS CHAPTER

- The ten most common retention mistakes in SMBs, shops and agencies
- A quick fix for each, with time and effort
- A self-score to find your biggest gap

After you have seen enough small businesses, the same mistakes keep appearing. None needs a lawyer. All of them need a decision.

The ten mistakes and the fix

#	Mistake	Quick fix
1	No retention periods at all	Write a one-page schedule for your five main data types
2	"Keep forever" as the default in every tool	Switch on auto-delete or expiry settings in each system
3	Vague privacy notice wording ("as long as necessary")	State real periods or clear criteria (Arts. 13 and 14)
4	Dormant marketing lists	Run a sunset campaign, then remove non-responders
5	Passport and ID scans kept after checking	Delete the scan once verified, and keep only the note that the check was done
6	Ex-employees' mailboxes and folders left open	Add a leaver routine with a deletion date
7	Backups kept indefinitely	Define a rotation and a re-deletion procedure
8	Client data left on laptops after projects end	Add an end-of-project deletion step and confirmation
9	Erasure requests handled in one system only	Use a checklist that covers every place data lives
10	No evidence of any deletion	Start a deletion log this month

Where do you stand?

Give yourself one point for each mistake you are **not** making today. Be honest: "not sure" counts as a mistake.

0 to 3	4 to 6	7 to 8	9 to 10
Hoarder	**Getting There**	**Tidy**	**Well Maintained**
Retention is not managed yet. Start with the one-page schedule, the leaver routine and the backup rule. Follow the 30-day plan in the next chapter.	You have good instincts and some gaps. Close the gaps where you scored zero and write the rules down.	A solid base. Add automation, evidence and an annual review.	You manage data through its whole life. Keep reviewing and watch for legal changes.

Figure 21 Your Retention Health score

The cost of fixing versus the cost of ignoring

WAITING

- Each month adds more data to the pile.
- A breach exposes more people, so notification and cleanup cost more.
- Access and erasure requests take longer and cost more staff time.
- Nobody can explain why records exist when a regulator or client asks.

FIXING NOW

- One short schedule and three automatic settings remove most of the pile.
- A breach exposes only what is genuinely needed.
- Requests are answered from a known list of places.
- You can answer "why do you still have this?" in one sentence.

Figure 22 Fixing retention now versus waiting

QUICK WINS FOR THIS WEEK

- [ ] Turn on automatic deletion for one log or inbox.
- [ ] Delete one old export file and note it in the deletion log.
- [ ] Remove ID scans you no longer need.
- [ ] Write down the backup rule for your main system.
- [ ] Add "delete data" to your end-of-project checklist.

PART IV · PUTTING IT TO WORK

CHAPTER

10

Your 30-Day Cleanup Plan

Four weeks, thirty minutes a day, from "we keep everything" to a working retention system.

IN THIS CHAPTER

- A four-week plan: discover, decide, document, delete
- Which tasks to do first for the biggest risk reduction
- How to keep the system alive after the first month

You do not need to fix everything at once. You need a sequence that reduces risk quickly and builds a habit. Thirty minutes a day is enough.

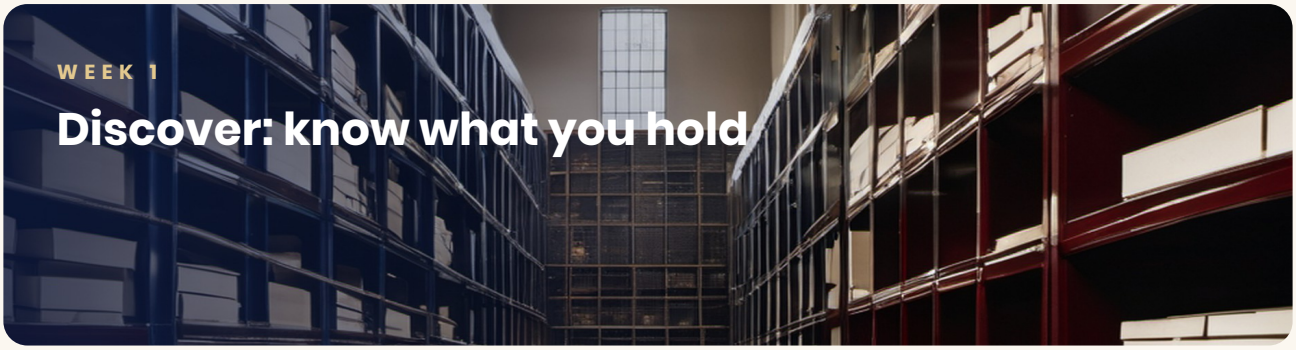
Week 1 — **Discover**
List your systems, map your data, find the oldest records and identify any legal minimums.

Week 2 — **Decide**
Choose a period, trigger, action and reason for each category. Name owners.

Week 3 — **Document**
Fill in the retention schedule, update your privacy notice, write the backup rule and the leaver routine.

Week 4 — **Delete**
Run the first clean-up, switch on automation, start the deletion log and set the annual review.

Figure 23 Your four weeks at a glance



DAY 1	**List every system that holds personal data** Shop, CRM, email, accounting, HR, helpdesk, drives, phones, paper	☐ DONE
DAY 2	**Map the categories** Customers, prospects, staff, applicants, suppliers, visitors	☐ DONE
DAY 3	**Find the oldest record in each system** Note the date and what it is for	☐ DONE
DAY 4	**Identify legal minimums** Ask your accountant about invoices, payroll and tax records	☐ DONE

DAY 5

List who has access
Remove anyone who does not need it

☐ DONE



WEEK 2

Decide: set the rules

DAY 8

Choose a trigger for each category
End of contract, last activity, decision date

☐ DONE

DAY 9

Choose a period
Start with the legal minimum, add a justified business need

☐ DONE

DAY 10

Choose an action
Delete, anonymise or review

☐ DONE

DAY 11

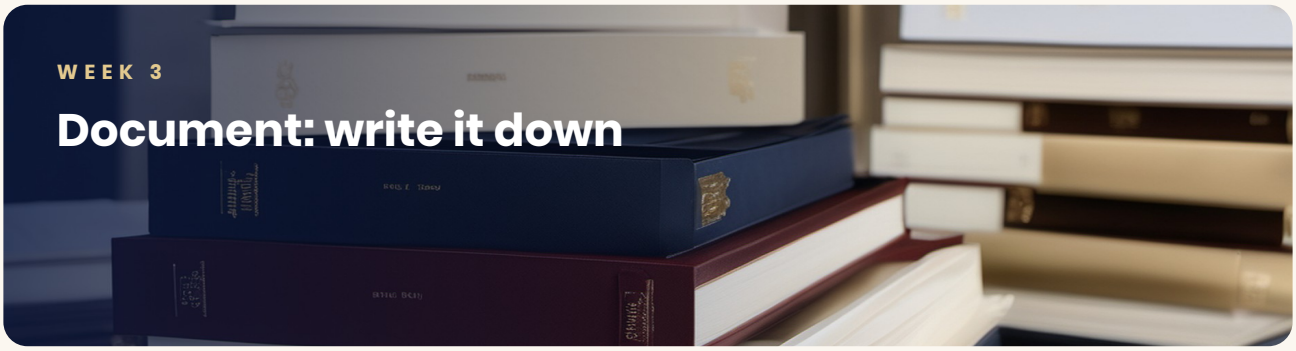
Write the "because"
One line of reason per period

☐ DONE

DAY 12

Name an owner
One person per area, with authority to delete

☐ DONE



WEEK 3

Document: write it down

DAY 15	**Complete the retention schedule** Use the template in the Bonus section	☐ DONE
DAY 16	**Update the privacy notice** State periods or criteria (Arts. 13 and 14)	☐ DONE
DAY 17	**Write the backup rule** Rotation, destruction, re-deletion after restore	☐ DONE
DAY 18	**Write the leaver routine** Accounts, devices, mailbox, HR file	☐ DONE
DAY 19	**Update vendor contracts** Check deletion and return clauses (Art. 28)	☐ DONE



WEEK 4

Delete: take action

DAY 22	**Switch on automatic deletion** Logs, carts, helpdesk, mailbox retention	☐ DONE
DAY 23	**Run the marketing sunset** Re-engagement email, then removal	☐ DONE
DAY 24	**Clean shared drives and exports** Delete old exports and duplicates	☐ DONE
DAY 25	**Clear former-employee data** Mailboxes, files, ID copies	☐ DONE
DAY 26	**Start the deletion log** Record what was deleted, when and by whom	☐ DONE
DAY 27	**Test a restore and the re-deletion step** Or ask your provider to confirm	☐ DONE
DAY 28	**Set the annual review** Put the date in everyone's calendar	☐ DONE

FOUNDER TIP **Founder Tip: start small, finish first**

A finished clean-up of one system beats a perfect plan for ten. Pick the system with the oldest data and the most personal information, and complete the whole four-week loop on that one. Then repeat.

Keeping it alive

MONTHLY
Ask "what did we delete?" in your team meeting. Check automatic rules still run. Add anything new to the schedule.

QUARTERLY
Clean marketing lists and shared drives. Process leaver files. Review open legal holds.

ANNUALLY
Review the whole schedule, the privacy notice and the backup rule. Test a restore. Record the review date.

Figure 24 The rhythm that makes it stick

THE COMPOUNDING RULE

You do not need a perfect retention system. You need a slightly tidier one each month.

Delete one old export this week. Switch on one expiry setting next week. Fix the privacy notice the week after. In a year you will have made fifty small improvements, and your business will be safer, lighter and easier to run than most of your competitors'.

When to ask a professional

Take advice from a qualified lawyer or data protection professional if you are unsure what national law requires you to keep, if you hold health or other special-category data at scale, if you have received a complaint or a regulator's inquiry, if a legal claim is possible, or if you are drafting contracts with large clients. Knowing when to ask is part of running a responsible business.

BONUS

Data Retention Policy Template

A ready-to-adapt policy, retention schedule, deletion log and review checklist. Fill in the brackets and the blank fields.

IN THIS CHAPTER

- A complete Data Retention Policy you can adapt in an hour
- A fillable retention schedule and deletion log
- A legal-hold record and an annual review checklist

WATCH OUT **How to use this template**

This is an **educational template, not legal advice**. Replace every [bracket] with your own details, delete sections that do not apply and add what is missing. Have your final version checked against the retention rules of your country and sector. The PDF fields can be filled in on screen or printed.

Data Retention Policy

[Business name] · Version [1.0] · Date [DD Month YYYY] · Owner [Name and role] · Next review [DD Month YYYY]

1. Purpose

This policy explains how long [Business name] keeps personal data, why, and how it is deleted or anonymised when it is no longer needed. It helps us comply with the storage limitation principle in Article 5(1)(e) of the GDPR and with our accountability duty under Article 5(2).

2. Scope

This policy applies to all personal data we hold about customers, prospects, website visitors, employees, applicants, suppliers and clients, in any form: digital, paper, backups, email and cloud tools. It applies to all staff, freelancers and processors who handle data on our behalf.

3. Principles

- We keep personal data only for as long as it is necessary for the purpose we collected it for, or as long as the law requires.
- Every category of data has a stated period, a trigger, an action and a reason, set out in the Retention Schedule.
- When a period ends, we delete or irreversibly anonymise the data, or document a new, specific reason to keep it.
- We tell people how long we keep their data in our privacy notices.
- We keep records of deletion without keeping the deleted data.

4. Roles and responsibilities

- **Policy owner:** [Name, role] maintains this policy and reviews it at least once a year.
- **Area owners:** [Names and areas, for example Marketing, Finance, HR, IT, Projects] apply the schedule in their area.
- **All staff:** follow the policy, do not create unnecessary copies and report any data kept beyond its period.

5. Retention periods and triggers

The Retention Schedule in section 12 sets the period, trigger, action and reason for each data category. Where a law sets a minimum period, we keep only the records the law requires, for that period. Where no law applies, we choose the shortest period that meets a documented business need.

6. Deletion and anonymisation

When a retention period ends, the area owner arranges permanent deletion from live systems, including any recycle bin, copies and exports. Paper records are destroyed by cross-cut shredding or certified destruction. Where we keep statistics, we first aggregate and irreversibly anonymise the data. Pseudonymised data is treated as personal data.

7. Backups and archives

We keep backups only for disaster recovery. Daily backups are kept for [30] days and monthly backups for [6 to 12] months, and then overwritten or destroyed. After any restore, we re-apply our deletion log so that data already erased does not return. Backups are not used for any other purpose.

8. Legal holds

If a legal claim, dispute, investigation or regulatory inquiry is reasonably foreseeable, [Policy owner] may place a legal hold on specific records. Holds are recorded in the Legal Hold Register, limited to the records concerned, reviewed every [3] months and released when the matter is closed.

9. Employees and applicants

Unsuccessful applicants' data is deleted [6] months after the decision unless the applicant agrees to remain on file. Employee records are kept during employment and afterwards only as required by law or for a documented need. Leavers' accounts and mailboxes are closed within [30] days of their last day.

10. Processors and clients

Our contracts with processors require deletion or return of personal data when services end, with written confirmation within [30] days. Where we act as a processor for clients, we delete or return client data at the end of each project according to the client's instruction.

11. Requests from individuals

Requests to delete data are logged and answered within one month. We delete everything we do not need to keep and explain clearly what we keep, why and until when.

12. Retention Schedule

RETENTION SCHEDULE

Data category	Purpose	System or location	Trigger	Period	Because (law or business need)	Action at end	Owner
e.g. Order invoices	*Accounting and tax*	*Accounting software*	*End of financial year*	*[7 years]*	*Tax law*	*Delete*	*Finance*

13. Review

This policy and the Retention Schedule are reviewed at least once a year and whenever we start using a new tool, collect a new kind of data or learn of a legal change. Each review is recorded below.

14. Deletion log

DELETION LOG

Date	Data category	System or location	Rule applied	Done by	Notes
e.g. 2026-03-01	*Inactive newsletter subscribers*	*Email platform*	*Marketing sunset, 24 months*	*A. Smith*	*1,240 removed*

15. Legal hold register

LEGAL HOLD REGISTER

Matter	Records covered	Start date	Reviewed	Released
e.g. Client dispute ref. 12	*Contract, emails, invoices*	2026-02-10	2026-05-10	*Open*

WORKSHEET

Annual Retention Review

Complete once a year and file it with this policy.

Date of review and who attended

Changes to the law, guidance or our tools since last year

Retention periods changed, and why

Backup rule tested? Result and date

Data categories added or removed

Actions agreed, owners and deadlines

ANNUAL REVIEW CHECKLIST

- [ ] The Retention Schedule matches the tools and data we really use.
- [ ] Privacy notices state accurate periods or criteria.
- [ ] Automatic deletion rules still run and are tested.
- [ ] The backup rotation is documented and a restore has been tested.
- [ ] Leaver deletions in the last year were completed.
- [ ] The deletion log is up to date and filed.
- [ ] Legal holds were reviewed and released where possible.
- [ ] Staff received a short reminder of the policy.

AI & PRIVACY **Where to go next**

Free tools, a privacy notice generator and updates on retention guidance are available at **gdprgard.eu**.

Plain-English Glossary

The retention vocabulary used in this book.

Accountability	The duty to comply with the GDPR principles and to be able to show that you do (Art. 5(2)).
Anonymisation	Making data impossible to link to a person by any means reasonably likely to be used. Truly anonymous data is outside the GDPR (Recital 26).
Backup	A copy of data kept for disaster recovery, not for everyday use.
Controller	The person or business that decides why and how personal data is processed.
Deletion log	A record of what was deleted, when, by whom and under which rule, without the deleted data itself.
Erasure (right to be forgotten)	The right to have personal data deleted in certain situations (Art. 17).
Legal hold	A temporary pause on deletion for records related to a specific dispute, claim or investigation.
Legal minimum	A period for which another law, such as tax or payroll law, requires specific records to be kept.
Personal data	Any information relating to an identified or identifiable living person (Art. 4(1)).
Processor	A business that processes personal data on behalf of a controller, under a contract (Art. 28).
Pseudonymisation	Replacing identifiers with codes while keeping the key separately. Still personal data (Art. 4(5)).
Retention period	The length of time a category of data is kept before it is deleted, anonymised or reviewed.
Retention schedule	A table of data categories with period, trigger, action, reason and owner.
Storage limitation	The principle that data must not be kept in identifiable form for longer than necessary (Art. 5(1)(e)).

Suppression list	A minimal record, such as an email address, kept to ensure someone who opted out is not contacted again.
Trigger	The event that starts a retention clock, such as the end of a contract or a financial year.

Official Sources & Further Reading

Where the legal claims in this book come from, and where to check what applies today.

Always prefer the primary sources below to summaries, including this one. Web addresses change: if a link has moved, search the official site for the title shown. Guidance is updated regularly, so check for the latest version before relying on it.

Primary EU law (EUR-Lex)

- **General Data Protection Regulation (GDPR)**, Regulation (EU) 2016/679. Notably Art. 4 (definitions, including pseudonymisation), Art. 5(1)(e) and 5(2) (storage limitation and accountability), Art. 6 (lawful bases), Art. 9 (special categories), Arts. 12 to 15 (transparency, access), Art. 17 (erasure), Art. 18 (restriction), Art. 21 (objection to marketing), Art. 25 (data protection by design and by default), Art. 28 (processors), Art. 30 (records), Art. 32 (security), Art. 83 (fines), Art. 88 (employment) and Art. 89 (archiving and research). Recitals 26 (anonymous data) and 39 (time limits and review). eur-lex.europa.eu/eli/reg/2016/679/oj

Regulators and guidance

- **European Data Protection Board (EDPB)**, general guidance and enforcement news: edpb.europa.eu
- **CNIL (France)**, guidance on retention periods and the Spartoo decision (2020): cnil.fr
- **Datatilsynet (Denmark)**, the Taxa 4x35 case (2019): datatilsynet.dk, and the EDPB news item "The Danish Data Protection Agency proposes a DKK 1,2 million fine for Danish taxi company".
- **Berlin Commissioner for Data Protection and Freedom of Information**, Deutsche Wohnen decision (2019), and the Court of Justice judgment in Case C-807/21 (5 December 2023) on fault and fines. Check the current status of the national proceedings.
- **Your national data protection authority**, for national retention guidance, employment rules and CCTV limits. Find yours on the EDPB website.

WATCH OUT **What this book could not verify for you**

The retention periods in Chapters 4 and 5 are illustrative starting points, not legal rules, and national tax, accounting, employment and sector laws differ. The enforcement cases in Chapter 1 are summarised from public reporting and regulator announcements and may have developed since. Check each against the primary source, and take advice from a qualified professional before relying on them.

About the Author

Zirlandia Milkovic

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that founders should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy founders can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Stay in touch

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other businesses find it.

AI & PRIVACY **Note to the reader**

This book is educational and not legal advice. Laws and guidance change, so check the sources in the previous section and consult a qualified professional about your own circumstances.


Keep what you need.
Delete what you don't.
Prove that you decided.
ZIRLANDIA MILKOVIC